

PLAYBOOK DI DETECTION & RESPONSE

Sospetto Pass-the-Hash / Lateral Movement via PsExec (ADMIN\$)

PB-PTH-001 v1.0 Virtual SOC Home Lab

Documento di esercitazione basato su un laboratorio controllato (Virtual SOC Home Lab). Le regole, gli Event ID e gli IP citati provengono dall'ambiente di test. In produzione, soglie, owner ed escalation path vanno adattati al runbook aziendale.

1. Scopo e contesto

Obiettivo: rilevare, validare, contenere ed eradicare un movimento laterale eseguito tramite Pass-the-Hash con PsExec-style execution (Impacket), in cui un attaccante usa un hash NT già ottenuto per autenticarsi via SMB e creare un servizio temporaneo su ADMIN\$ ottenendo una shell SYSTEM.

Quando si applica: ogni alert riconducibile a creazione di servizio da percorso di sistema, logon NTLM type 3 da sorgente inattesa, o burst di logon di rete verso una workstation/server.

MITRE ATT&CK: T1550.002 (Pass-the-Hash), T1021.002 (SMB/Windows Admin Shares), T1569.002 (Service Execution), T1543.003 (Create or Modify System Process: Windows Service).

2. Trigger / segnali di detection

Il playbook si attiva su uno o più dei seguenti segnali. La regola primaria è la 92650.

Sorgente	Segnale	Severità	Tecnica
Wazuh	Rule 92650 – New Windows Service from root path (binario droppato via Admin Shares)	L12 – Critica	T1021.002 / T1569.002
Wazuh	Rule 92652 – Successful Remote Logon, NTLM (possibile Pth), spesso x4 in rapida successione	L6	T1550.002
Wazuh	Rule 67028 – Special privileges assigned to new logon (alterna a 92652)	L3	–
Security Onion	EID 4624 logon type 3, NtLmSsp NTLM V2, da IP inatteso (via syslog da Wazuh)	Info/Corr.	T1021.002
Custom	Rule 100002/100004 – burst di logon NTLM type 3 (pattern automatizzato Pass-the-Hash)	L6→L12	T1550.002

3. Triage e verifica (primi 15 minuti)

Sequenza di verifica per stabilire se l'alert è un True Positive prima di avviare la procedura di escalation. Ad ogni passo annota l'evidenza nel ticket.

- Conferma l'alert primario.** Apri la Rule 92650 in Wazuh Threat Hunting. Estrai: host di destinazione, nome del servizio temporaneo (es. firma a 4-8 caratteri tipo "UfwS"), path del binario in %systemroot%.
- Identifica la sorgente del logon.** Correla con EID 4624 type 3 + NTLM. Annota l'IP/host sorgente. **Discriminante chiave:** sorgente = IP Kali esterno → attacco verticale; sorgente = host interno già noto → movimento east-west (peggiore).

3. **Verifica il target user.** È un account privilegiato (Administrator/Domain Admin)? O un Account macchina (\$) ? Gli account macchina sono rumore atteso e vanno soppressi (Rule 100003).
4. **Cerca la catena a monte.** Negli ultimi 60 minuti sullo stesso dominio: disabilitazione Defender (Rule 62152), credential dump / DCSync, logon WinRM (evil-winrm). Se presenti, è una kill chain completa → P1.
5. **Escludi il falso positivo legittimo.** Tool di amministrazione/deploy (SCCM, PsExec legittimo da jump host autorizzato), scanner autorizzati (es. IP scanner GVM). Verifica che la sorgente sia in whitelist documentata.

Esito del triage → True Positive (escalation), False Positive (attività reale ma autorizzata: documenta eccezione), o False Positive (chiudi con motivazione). *Un FP non si silenzia: si capisce, si documenta, si gestisce.*

4. Criteri di escalation (L1 → L2/IR)

Condizione osservata	Verdetto	Azione
Rule 92650 confermata + target = account privilegiato + sorgente non whitelisted	P1 Critico	Escalation immediata a L2/IR Lead
Catena con DCSync / dump NTDS / hash krbtgt esfiltrato	P1 Critico	Escalation immediata + attiva owner AD
Rule 92650 da host interno (movimento east-west)	P1-P2	Escalation immediata a L2
92652 isolato, nessuna creazione servizio, sorgente whitelisted	False positive	Documenta e chiudi
Account macchina (\$) come target, nessun altro segnale	Rumore	Sopprimi (Rule 100003)

Regola di mandato L1: la compromissione di un account Domain Admin, il dump di NTDS.DIT o l'esfiltrazione dell'hash krbtgt eccedono il mandato Tier 1 e richiedono escalation immediata e l'attivazione del processo IR formale.

5. Contenimento

Il containment precede sempre l'eradicazione per impedire la propagazione ad altri host. Preserva i sistemi per la forensics (non spegnere, piuttosto isola).

- **Isola l'host target e la sorgente:** quarantena NAC / disabilitazione porta switch. Nel lab:

```
New-NetFirewallRule -DisplayName CONTAINMENT -Direction Outbound -RemoteAddress <IP> -Action Block
```
- **Disabilita gli account compromessi** e revoca le sessioni Kerberos/NTLM attive.
- **Blocca l'IP/host attaccante** a livello perimetrale e di segmento.

6. Eradicazione e ripristino

1. **PRIORITÀ 1 – Doppio reset di krbtgt** (due reset consecutivi, intervallo ≥ un ciclo di replica) se l'hash krbtgt risulta esfiltrato, altrimenti qualsiasi Golden Ticket già forgiato resta valido.
2. Reset password di tutti gli account presenti nel dump NTDS, a partire dai privilegiati.
3. Riattiva e verifica Windows Defender Real-Time Monitoring; conferma assenza di esclusioni residue.
4. Rimuovi servizio e binario temporanei lasciati da PsExec; reimaging della workstation (compromissione SYSTEM).

5. Verifica integrità del DC (o ricostruzione per asset Tier 0) e ripristino della baseline di sicurezza.

7. Hardening preventivo

- Disabilita LLMNR e NBT-NS via GPO: rimuove la fonte primaria del furto di credenziali a monte della catena.
- Modello di tiering degli account amministrativi + LAPS per gli admin locali: limita il riuso di credenziali nel lateral movement.
- Abilita audit DRSUAPI/DCSync: EID 4662 con i GUID di replica, e audit accesso a SAM/NTDS (EID 4656/4663) per coprire il gap di detection del credential dump.
- WinRM: CbtHardeningLevel = Strict, IPv4Filter ristretto agli IP autorizzati; disabilita Print Spooler sul DC.